SECURITY-ASSURANCE-TPM-FIPS-CC

TPM·FIPS140-2·CC·신속확인 제도

연관 기출 · 132-1-8, 132-4-1, 136-1-11, 129-1-11

한눈에 이해

암호 알고리즘, 키를 다루는 모듈, 제품이 주장하는 보안 기능은 각각 보증 범위가 다릅니다.

정의와 핵심 원리

TPM은 키 보호, 측정값 보관과 상태 증명을 지원하는 신뢰 기반 모듈입니다. FIPS 140은 암호 모듈의 보안 요구를, CC는 정해진 평가 대상의 보안 기능과 보증 요구를 다룹니다. 신속확인은 기존 평가 기준이 없는 신기술 보안 제품의 공공 도입을 돕는 국내 제도입니다.

• TPM은 PCR에 저장한 측정값을 이용해 정해진 상태에서만 보호된 데이터를 사용할 수 있게 하거나, 측정 결과를 증명하는 데 쓰입니다. 측정 부팅은 구성 변경의 증거를 제공합니다. 실행 중 위협 대응과 키 소유권·등록·복구, 펌웨어와 물리적 공격도 따로 고려합니다.

• FIPS 140-2의 1~4단계는 암호 모듈의 보증 수준입니다. 모듈 명세·역할과 인증·물리 보안·운영 환경·키 관리·자가시험 등을 평가합니다. 대표 특징은 1단계 기본 요구, 2단계 물리적 변조 흔적과 역할 기반 인증, 3단계 강화된 물리 보호와 신원 기반 인증, 4단계 포괄적 물리 보호와 환경 대응입니다. 세부 요구는 해당 수준의 원문을 확인합니다.

• CC에서는 평가 대상(TOE), 보안목표명세서(ST), 보호프로파일(PP)과 기능·보증 요구를 구분합니다. 평가 수준은 해당 평가 범위에서 해석합니다. 신속확인은 취약점·소스 보안 약점 점검과 보안성 심사의 적용 범위를 확인합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
TPM	키 보호·측정·증명	플랫폼 신뢰를 뒷받침하는 요소
FIPS 140	암호 모듈 보안	모듈, 제품, 전체 서비스의 범위 구분
CC·신속확인	제품 보안 평가	대상·판본·유효성 확인

적용 예제

보안모듈 구매 검토

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 공공 업무에 사용할 AES 지원 제품을 검토합니다.

1. 인증서의 모듈 이름과 버전, 운영 모드, 보안 경계를 확인합니다.

2. 승인된 알고리즘을 지원하는지, 모듈 자체가 검증받았는지 구분합니다.

3. 키 생성·백업·복구와 관리자 역할·감사 요구를 검토합니다.

4. 실제 배포 버전이 평가 대상에 포함되는지 확인합니다.

결과·해석: 평가 범위와 운영 조건을 실제 배포 환경에 대조해 보증이 적용되는 부분을 확인합니다.

전제·주의: FIPS 140-2 원문은 확인했습니다. 140-3 전환, CC 현행 절차, 신속확인의 최신 요건은 확인이 남아 있습니다.

답안 골격과 혼동 방지

보증 범위 비교 → TPM 활용 → FIPS 140-2의 네 단계 → CC 핵심 용어 → 도입 시 확인 사항

- FIPS 140-2 단계는 모듈의 보안 요구 수준입니다. 암호 키 길이는 별도로 확인합니다.
- TPM이 있으면 어떤 플랫폼 상태를 측정하고 증명할 수 있는지 확인합니다.

내용을 가리고 회상

1. 암호 알고리즘 검증과 모듈 검증은 어떻게 다릅니까?

2. TPM으로 상태를 측정하는 것과 실행을 차단하는 것은 어떻게 다릅니까?

3. CC 평가 범위를 확인해야 하는 이유는 무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- TPM2.0 Library - Trusted Computing Group; 상시 규격목록; 확인 2026-11-05.
- FIPS140-2 Security Requirements for Cryptographic Modules - NIST; 2001-05-25;2002정정; 확인 2026-11-05.